Nachweisliste

Betrieb: Muster Elektrotechnik e.U. Datum: 19. Oktober 2026

Nachweisordner: Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro

27 Nachweise, die ein Fragebogen typischerweise verlangt. 10 liegen vor oder entstehen mit diesem Toolkit und bekommen eine Anlagennummer; die übrigen tragen den Termin aus dem Maßnahmenplan. Ein Kunde liest diese Liste als Anlagenverzeichnis der Selbstauskunft.

Vorhanden: Anlagen

Nr.	Nachweis	Belegt	Status	Wo
A1	Selbstauskunft Informationssicherheit (D1)	Alle Abschnitte	aus dem Toolkit	Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro
A2	Zuständigkeiten: verantwortliche Person, Vertretung, Erreichbarkeit	Abschnitt A	aus dem Toolkit	Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro
A3	Maßnahmenplan mit Terminen (D2)	Jedes „teilweise“ und „noch nicht“	aus dem Toolkit	Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro
A4	Kontenliste ohne geteilte Logins.	C1 · Hat jede Person ein eigenes Konto, ohne geteilte Logins?	vorhanden	Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro

Nr.	Nachweis	Belegt	Status	Wo
A5	Bildschirmfoto der Einstellung je Konto oder der Administratorbericht; Wiederherstellungscodes offline abgelegt.	C2 · Ist die Multi-Faktor-Authentifizierung für jedes E-Mail-Konto eingeschaltet?	vorhanden	Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro
A6	Update-Einstellungen; Notiz der monatlichen Prüfung.	E1 · Werden Updates auf jedem Computer, Telefon und Server automatisch innerhalb von Tagen installiert?	vorhanden	Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro
A7	Einstellungen je Gerät in der Geräteliste.	E3 · Ist auf jedem Computer eine Schutzsoftware aktiv, und sind Notebooks und Telefone verschlüsselt?	vorhanden	Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro
A8	Klausel in den Verträgen oder unterschriebene Zusätze.	G2 · Sind die Beschäftigten schriftlich zur Vertraulichkeit verpflichtet, etwa im Dienstvertrag?	vorhanden	Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro
A9	Schriftliche Regel; Teil der Einweisung.	G3 · Gibt es eine Regel für Zahlungen: Jede Änderung von Bankdaten und jede ungewöhnliche Zahlungsaufforderung wird per Rückruf unter einer bekannten Nummer bestätigt?	vorhanden	Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro
A10	Regel; Vorlage der Bestätigung.	I1 · Werden am Ende eines Vertrags die Daten des Kunden zurückgegeben oder gelöscht, und können Sie das schriftlich bestätigen?	vorhanden	Ordner „Sicherheit“ auf dem Büroserver und der Papierordner im Büro

Fehlt: mit Termin

Nachweis	Belegt	Fällig	So entsteht er
Notfallkarte, gedruckt und ausgehängt (D3)	Abschnitte D und F	18. November 2026	aus dem Toolkit
Unterschriebene Regeln mit Datum; Liste der Kenntnisnahmen.	B1 · Gibt es schriftliche Sicherheitsregeln für die Belegschaft: Geräte, Passwörter, E-Mail, was zu melden ist?	17. Jänner 2027	Die Sicherheitsregeln für die Belegschaft auf ein bis zwei Seiten schreiben: Geräte, Passwörter, E-Mail, Zahlungen, was gemeldet wird und an wen. Die Leitung unterschreibt, jede Person bestätigt die Kenntnisnahme.
Bildschirmfotos oder Administratorbericht je System.	C3 · Ist sie für Fernzugriff, Administratorkonten, Cloud-Konsolen und Online-Banking eingeschaltet?	18. November 2026	Multi-Faktor-Authentifizierung für Fernzugriff (VPN, Remote Desktop), jedes Administratorkonto, die Cloud-Konsolen und das Online-Banking einschalten.
Kontenliste; Austrittscheckliste mit Daten.	C4 · Werden die Konten ausscheidender Personen am selben Tag deaktiviert, anhand einer Liste aller Konten?	17. Jänner 2027	Die Liste aller Konten je Person schreiben und eine Austrittscheckliste anlegen, die sie am Tag des Ausscheidens deaktiviert. Beim nächsten Austritt proben.
Kontenliste mit täglichen und Administratorkonten.	C5 · Wird die tägliche Arbeit ohne Administratorrechte erledigt, mit getrennten Konten für die Administration?	17. Jänner 2027	Administratorrechte aus den täglichen Konten entfernen und getrennte Administratorkonten anlegen, die nur für die Administration benutzt werden.
Schriftliche Regel; Passwort-Manager eingeführt (Lizenz oder Bildschirmfoto).	C6 · Gibt es eine Passwortregel: ein langes Passwort je Konto in einem Passwort-Manager, nur bei Verdacht geändert?	17. Jänner 2027	Einen Passwort-Manager für alle einführen und die Regel schreiben: ein langes Passwort je Konto, fünfzehn Zeichen oder mehr ohne zweiten Faktor, nur bei Verdacht geändert, gegen Leck-Listen geprüft.
Sicherungseinstellungen und Zeitplan; wo die Kopie außer Reichweite liegt.	D1 · Werden alle Geschäftsdaten täglich automatisch gesichert, mit einer Kopie offline oder sonst außerhalb der Reichweite eines Angreifers?	18. November 2026	Tägliche automatische Sicherung aller Geschäftsdaten einrichten, mit einer Kopie außerhalb der Reichweite eines Angreifers: offline, auf einer gewechselten Platte oder in einer Cloud-Kopie, die sich vom Büro aus nicht löschen lässt.
Protokoll des Wiederherstellungstests mit Datum und Dauer.	D2 · Wurde in den letzten zwölf Monaten eine Wiederherstellung aus der Sicherung geprobt, mit notierter Dauer?	18. November 2026	Einen Ordner aus der Sicherung zurückspielen, die Zeit stoppen, Datum, Dauer und Ergebnis notieren. Einmal im Jahr wiederholen.

Nachweis	Belegt	Fällig	So entsteht er
Geräteliste mit Daten.	E2 · Gibt es eine Liste aller Geräte, und wird jedes Gerät und Programm vom Hersteller noch unterstützt?	17. Jänner 2027	Die Geräteliste schreiben: Gerät, Nutzer, System, unterstützt bis. Jedes Gerät ersetzen oder vom Netz nehmen, dessen System nicht mehr unterstützt wird.
Router-Einstellungen und das Datum der Prüfung.	E5 · Ist der Router oder die Firewall aktuell, mit geändertem Administratorpasswort, abgeschalteter Fernadministration und einem getrennten Gastnetz für Besucher?	17. Jänner 2027	Router oder Firewall aktualisieren, das Administratorpasswort ändern, die Fernadministration abschalten, das Gastnetz vom Betriebsnetz trennen.
Notfallkarte; die Namen in den Regeln.	F2 · Ist bekannt, wer nach einem Vorfall prüft, ob personenbezogene Daten betroffen sind, und wer binnen 72 Stunden an die Datenschutzbehörde meldet?	18. November 2026	Benennen, wer nach einem Vorfall prüft, ob personenbezogene Daten betroffen sind, und wer binnen 72 Stunden nach Kenntnis an die Datenschutzbehörde meldet. Beides auf die Notfallkarte.
Vorfallsprotokoll, auch wenn noch leer, mit Datum.	F4 · Werden Vorfälle aufgeschrieben: Was ist passiert, auf welchem Weg, was hat gefehlt, was wurde geändert?	17. Jänner 2027	Ein Vorfallsprotokoll anlegen: eine Seite je Vorfall mit dem, was passiert ist, auf welchem Weg, was gefehlt hat, was geändert wurde, wer es geprüft hat.
Teilnehmerliste mit Datum und Inhalten.	G1 · Wurde die Belegschaft in den letzten zwölf Monaten zu Phishing, Passwörtern und dem Meldeweg eingewiesen, mit Teilnehmerliste?	17. Jänner 2027	Eine halbstündige Einweisung zu Phishing, Passwörtern, Zahlungen und dem Meldeweg halten. Die Teilnehmerliste mit Datum und Inhalten aufbewahren. Einmal im Jahr und bei jedem Neueintritt wiederholen.
Dienstleisterliste mit Land und Zweck.	H1 · Gibt es eine Liste der Dienstleister, die Ihre Daten oder die Ihrer Kunden verarbeiten: E-Mail, Dateiablage, Buchhaltung, Website-Hosting, mit Land und Zweck?	17. Jänner 2027	Die Liste der Dienstleister schreiben, die Ihre Daten oder die Ihrer Kunden verarbeiten: Anbieter, Land, Zweck, Vertrag, Kontakt.

Nachweis	Belegt	Fällig	So entsteht er
Verträge abgelegt; Konsoleneinstellungen.	H2 · Haben Sie mit diesen Dienstleistern Auftragsverarbeitungsverträge, und sind deren Sicherheitseinstellungen (Multi-Faktor-Authentifizierung, zwei Administratoren) eingeschaltet?	17. Jänner 2027	Von jedem Dienstleister, der personenbezogene Daten im Auftrag verarbeitet, den Auftragsverarbeitungsvertrag einholen, und in jeder Anbieterkonsole die Multi-Faktor-Authentifizierung und eine zweite Administratorin einrichten.
Regel; E-Mail-Vorlage.	H3 · Würden Sie den Kunden informieren, bevor Sie einen Dienstleister wechseln, der seine Daten verarbeitet?	17. April 2027	In die Regeln aufnehmen, dass der Kunde informiert wird, bevor ein Dienstleister gewechselt wird, der seine Daten verarbeitet; eine Vorlage für die E-Mail bereithalten.

Nicht anwendbar

- Veröffentlichter Kontakt und Angabe zum Unterstützungszeitraum. (E4 · Wenn Sie Software oder Geräte liefern: Gibt es einen Kontakt für Schwachstellenmeldungen und einen Unterstützungszeitraum für Ihre Produkte?)

Erzeugt mit dem Sicherheitsnachweis-Toolkit von Scutoria aus den Antworten des Betriebs. Ob ein Kunde einen Nachweis anerkennt, entscheidet der Kunde. Quellenbasiert. Keine Rechtsberatung.